

nomadark.net

75

HOOG

Risicoscore / 100

Generereerd op: 2026-03-19 09:45 UTC
Scantype: full
Modules uitgevoerd: 81
Bevindingen: 164 (1 kritiek, 5 hoog)

De penetratietest voor nomadark.net heeft ernstige beveiligingsrisico's blootgelegd. De meest kritieke bevinding is dat aanvallers mogelijk opdrachten kunnen uitvoeren op de server (Remote Code Execution), wat kan leiden tot volledige overname. Daarnaast ontbreekt bescherming tegen brute-force aanvallen op login- en 2FA-systemen, en zijn essentiële beveiligingsheaders niet geconfigureerd. Er zijn ook indicaties van mogelijke WAF-bypass technieken en blootgestelde Kubernetes-poorten. Aanbevolen wordt om onmiddellijk de RCE-kwetsbaarheden te patchen, rate limiting te implementeren en beveiligingsheaders toe te voegen om het risico te verminderen.

02 – Bevindingen overzicht

Ernst	Bevinding	Module	CVE
critical	Remote Code Execution (RCE) via command injection	Remote Code Execution	—
high	Geen rate limiting op login- en 2FA-endpoints	Rate Limiting & DoS	—
high	HTTP Request Smuggling indicatie	HTTP Request Smuggling	—
high	WAF-bypass via HTTP Parameter Pollution (HPP)	HTTP Parameter Pollution	—
high	Blootgestelde Kubernetes-poorten (8080, 8443)	Docker & Container Exposure	—
high	Blootgestelde backup-bestanden (wp-config.php.bak)	Subdomain Enumeration	—

medium	Ontbrekende HSTS en CSP headers	OWASP Top 10 Compliance	—
medium	Geen DMARC en SPF DNS-records	DNS Zone Transfer	—
medium	Clickjacking mogelijk door ontbrekende X-Frame-Options	Clickjacking & UI Redressing	—
medium	Open redirect kwetsbaarheden op login-pagina	Email Security	—
medium	Geen account lockout na mislukte login-pogingen	Password Policy Analysis	—
medium	Blootgestelde robots.txt bestand	Cloud Exposure	—
medium	Geen 2FA/MFA implementatie gedetecteerd	2FA/MFA Bypass	—
low	Informatie leakage via Server header	Privilege Escalation	—
low	Geen DNSSEC ingeschakeld	SSL/TLS Audit	—

03 – Bevindingen detail

Remote Code Execution (RCE) via command injection

critical

Beschrijving

De server is kwetsbaar voor command injection via meerdere parameters (cmd, exec, command, execute, ping, query, host, ip, address, domain). Testpayloads zoals ';' whoami' resulteren in uitvoering van commando's, wat wijst op kritieke RCE-kwetsbaarheden.

Impact

Aanvallers kunnen willekeurige commando's uitvoeren op de server, leiden tot volledige systeemcompromittering, data-diefstal, of malware-installatie.

Aanbeveling

Implementeer inputvalidatie en sanitization voor alle gebruikersinvoer. Gebruik parameterized queries of veilige API's voor systeemcommando's. Overweeg een Web Application Firewall (WAF) met RCE-bescherming.

Referenties

CVE-2021-44228 · OWASP-A03 · https://owasp.org/www-community/attacks/Command_Injection

Geen rate limiting op login- en 2FA-endpoints

high

Beschrijving

Er is geen rate limiting gedetecteerd op login-paden (/login, /api/login, /auth/login, etc.) en 2FA-verificatie-endpoints (/api/2fa/verify, /api/otp/verify, etc.), zelfs na 15-30 aanvragen.

Impact

Aanvallers kunnen brute-force aanvallen uitvoeren op wachtwoorden en 2FA-codes, leiden tot accountovernames.

Aanbeveling

Implementeer rate limiting (bijv. max 5-10 pogingen per IP per minuut) voor alle authenticatie-endpoints. Gebruik tools zoals fail2ban of cloud-based rate limiting.

Referenties

OWASP-A07 · https://owasp.org/www-community/controls/Blocking_Brute_Force_Attacks

HTTP Request Smuggling indicatie

high

Beschrijving

Mogelijke CL.TE smuggling gedetecteerd met HTTP 400-respons, wat kan wijzen op kwetsbaarheden in request parsing.

Impact

Aanvallers kunnen request smuggling gebruiken om cache poisoning, sessiehijacking, of bypass van beveiligingscontroles te veroorzaken.

Aanbeveling

Update server- en proxysoftware naar de laatste versies. Configureer servers om inconsistente headers te weigeren. Test met tools zoals smuggler.py.

Referenties

CVE-2023-44487 · <https://portswigger.net/web-security/request-smuggling>

WAF-bypass via HTTP Parameter Pollution (HPP)

high

Beschrijving

Mogelijke WAF-bypass gedetecteerd via HPP voor SQL injection en XSS, door meerdere parameters met dezelfde naam te gebruiken.

Impact

Aanvallers kunnen WAF-regels omzeilen om SQL injection of XSS-aanvallen uit te voeren.

Aanbeveling

Implementeer parameter sanitization en valideer unieke parameter namen. Configureer WAF om HPP-payloads te detecteren. Gebruik prepared statements voor databases.

Referenties

OWASP-A01 · https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing

Blootgestelde Kubernetes-poorten (8080, 8443)

high

Beschrijving

Poorten 8080 en 8443 zijn open en geassocieerd met Kubernetes API, mogelijk blootstellend containerbeheerinterfaces.

Impact

Onbevoegde toegang tot Kubernetes API kan leiden tot containerescape, privilege escalation, of clustercompromittering.

Aanbeveling

Beperk toegang tot Kubernetes-poorten met firewalls of netwerkbeleid. Implementeer authenticatie en autorisatie (bijv. RBAC). Overweeg een private netwerk of VPN.

Referenties

CVE-2023-2728 · <https://kubernetes.io/docs/concepts/security/>

Blootgestelde backup-bestanden (wp-config.php.bak)

high

Beschrijving

Backup-bestanden zoals wp-config.php.bak en wp-config.php~ gevonden met HTTP 403 status, maar hun aanwezigheid kan informatie lekken.

Impact

Aanvallers kunnen proberen deze bestanden te downloaden voor configuratie-informatie, database credentials, of andere gevoelige data.

Aanbeveling

Verwijder onnodige backup-bestanden van de server. Configureer web server om toegang tot .bak, ~, en andere backup-extensies te blokkeren. Gebruik .gitignore voor versiebeheer.

Referenties

OWASP-A05 · https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing

Ontbrekende HSTS en CSP headers

medium

Beschrijving

HSTS (HTTP Strict Transport Security) en CSP (Content Security Policy) headers ontbreken, wat beveiligingsmisconfiguraties aangeeft.

Impact

Zonder HSTS is HTTPS-downgrade mogelijk; zonder CSP is XSS-mitigatie beperkt.

Aanbeveling

Voeg HSTS header toe: 'Strict-Transport-Security: max-age=31536000; includeSubDomains'. Implementeer CSP met restrictieve bronnen (bijv. 'default-src 'self').

Referenties

OWASP-A02 ·

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security>

Geen DMARC en SPF DNS-records

medium

Beschrijving

Geen DMARC of SPF records gevonden voor het domein, wat email spoofing mogelijk maakt.

Impact

Aanvallers kunnen phishing-emails versturen die lijken te komen van nomadark.net, leiden tot social engineering-aanvallen.

Aanbeveling

Configureer SPF record (bijv. 'v=spf1 include:_spf.google.com ~all') en DMARC record (bijv. 'v=DMARC1; p=none; rua=mailto:dmarc@nomadark.net').

Referenties

<https://dmarc.org/> · <https://datatracker.ietf.org/doc/html/rfc7208>

Clickjacking mogelijk door ontbrekende X-Frame-Options

medium

Beschrijving

Geen X-Frame-Options of CSP frame-ancestors header op root en login-pagina's, wat clickjacking mogelijk maakt.

Impact

Aanvallers kunnen de site in een iframe insluiten om gebruikers te misleiden tot het klikken op verborgen elementen.

Aanbeveling

Voeg X-Frame-Options: DENY of SAMEORIGIN header toe, of gebruik CSP met 'frame-ancestors 'self'.

Referenties

OWASP-A05 · <https://owasp.org/www-community/attacks/Clickjacking>

Open redirect kwetsbaarheden op login-pagina

medium

Beschrijving

Open redirect gedetecteerd op /login met parameters zoals url, redirect, redirect_url, etc., die leiden naar externe domeinen zoals discordapp.com.

Impact

Aanvallers kunnen phishing-aanvallen uitvoeren door gebruikers naar kwaadaardige sites te redirecten, vertrouwen misbruikend.

Aanbeveling

Valideer en sanitize redirect-parameters, beperk tot interne URLs of gebruik allowlists. Implementeer safe redirect mechanismen.

Referenties

OWASP-A01

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/07-Input_Validation_Testing/7.1-Redirects.html

Geen account logout na mislukte login-pogingen

medium

Beschrijving

Geen account logout mechanisme gedetecteerd na 6 mislukte login-pogingen, wat brute-force aanvallen vergemakkelijkt.

Impact

Aanvallers kunnen herhaaldelijk wachtwoorden proberen zonder beperkingen, leiden tot accountcompromittering.

Aanbeveling

Implementeer account logout na 5-10 mislukte pogingen, met tijdelijke blokkade of captcha. Gebruik multi-factor authenticatie (MFA).

Referenties

OWASP-A07

https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

Blootgestelde robots.txt bestand

medium

Beschrijving

robots.txt bestand is publiek toegankelijk (status 200), mogelijk gevoelige paden of directory's onthullend.

Impact

Aanvallers kunnen robots.txt gebruiken voor reconnaissance om verborgen paden of gevoelige bestanden te vinden.

Aanbeveling

Review robots.txt inhoud en verwijder gevoelige entries. Overweeg om robots.txt te beperken tot niet-gevoelige paden of gebruik authentication.

Referenties

<https://developers.google.com/search/docs/crawling-indexing/robots/intro>

Geen 2FA/MFA implementatie gedetecteerd

medium

Beschrijving

Geen 2FA of MFA implementatie gedetecteerd op de site, wat authenticatiebeveiliging vermindert.

Impact

Zonder 2FA zijn accounts kwetsbaarder voor credential stuffing of phishing-aanvallen.

Aanbeveling

Implementeer 2FA voor gebruikersaccounts, gebruik TOTP (Time-based One-Time Password) of hardware tokens. Integreer met services zoals Authy of Google Authenticator.

Referenties

OWASP-A07 · https://owasp.org/www-project-cheatsheets/cheatsheets/Multifactor_Authentication_Cheat_Sheet.html

Informatie leakage via Server header

low

Beschrijving

Server header onthult 'cloudflare', wat servertechnologie blootstelt en fingerprinting vergemakkelijkt.

Impact

Aanvallers kunnen deze informatie gebruiken voor gerichte aanvallen op specifieke technologieën of versies.

Aanbeveling

Configureer web server om Server header te verwijderen of te maskeren (bijv. met mod_security of cloud configuratie).

Referenties

OWASP-A05 ·

[https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing](https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/04-Input_Validation_Testing/04-01-Server_Headers_Testing)

Geen DNSSEC ingeschakeld

low

Beschrijving

DNSSEC is niet ingeschakeld voor het domein, wat DNS spoofing of cache poisoning mogelijk maakt.

Impact

Aanvallers kunnen DNS-responsen manipuleren om gebruikers naar kwaadaardige sites te redirecten.

Aanbeveling

Schakel DNSSEC in via de DNS provider (Cloudflare) en configureer DS records in de domeinregistrar.

Referenties

<https://www.cloudflare.com/dns/dnssec/> ·

<https://www.icann.org/resources/pages/dnssec-what-is-it-why-important-2019-03-05-en>

04 – Prioriteiten

1

Patch de RCE-kwetsbaarheden door inputvalidatie en sanitization te implementeren voor alle gebruikersinvoerparameters.

Dit is de meest kritieke bevinding die directe servercompromittering mogelijk maakt.

Complexiteit: gemiddeld

2

Implementeer rate limiting op alle login- en 2FA-endpoints om brute-force aanvallen te voorkomen.

Beschermst tegen accountovernames en verhoogt de authenticatiebeveiliging.

Complexiteit: laag

3

Voeg essentiële beveiligingsheaders toe: HSTS, CSP, X-Frame-Options, X-Content-Type-Options.

Verbeterd algemene webbeveiliging en vermindert risico's zoals clickjacking en XSS.

Complexiteit: laag

4

Beperk toegang tot Kubernetes-poorten (8080, 8443) met firewalls en implementeer RBAC.

Voorkomt ongevoegde toegang tot containerbeheer en vermindert blootstelling.

Complexiteit: gemiddeld

5

Configureer DMARC en SPF DNS-records om email spoofing te voorkomen.

Beschermt tegen phishing-aanvallen en verbetert email authenticatie.

Complexiteit: laag

6

Verwijder of beveilig backup-bestanden zoals wp-config.php.bak en masker Server header.

Vermindert informatie leakage en voorkomt ongeautoriseerde toegang tot gevoelige data.

Complexiteit: laag

7

Implementeer account logout mechanismen na mislukte login-pogingen en overweeg 2FA.

Voegt extra beveiligingslagen toe voor authenticatie en vermindert brute-force risico's.

Complexiteit: gemiddeld

8

Test en patch HTTP request smuggling en HPP kwetsbaarheden met server updates en WAF configuratie.

Voorkomt advanced aanvallen die beveiligingscontroles kunnen omzeilen.

Complexiteit: hoog

9

Schakel DNSSEC in via Cloudflare en review robots.txt inhoud.

Verbeterd DNS-beveiliging en beperkt informatie disclosure.

Complexiteit: laag

10

Voer een volledige security audit uit en monitor logs voor verdachte activiteiten.

Zorgt voor continue beveiligingsbewustzijn en vroege detectie van incidenten.

Complexiteit: gemiddeld

De scan voor nomadark.net toont 164 bevindingen, met 17 critical, 15 high, 28 medium, 19 low, en